

格式字符串漏洞

版权所有 © 2017 杜文亮,保留所有权利。

允许个人使用。如需在课堂上使用这些习题,仅当该课程采用作者的著作作为教材时方可允许。所有其他用途均须事先征得作者的同意。

S6.1. 请编写一个函数,该函数接受可变数量的字符串作为参数,并打印出它们的总长度。

S6.2. 缓冲区溢出漏洞和格式化字符串漏洞都会导致返回地址字段被修改,但这两种攻击修改字段的方式不同。请描述它们的区别,并说明哪一种攻击的限制更少。

S6.3. 我们能否利用 StackGuard 的思想来防止格式化字符串攻击?

S6.4. 当执行 `printf(fmt)` 时,堆栈 (从低地址到高地址)包含以下值 (每个值 4 字节),其中第一个数字是变量 `fmt` 的内容,`fmt` 是一个指向格式字符串的指针。如果您可以确定格式字符串的内容,那么使用最少多少个格式说明符才能 100% 导致程序崩溃?

```
0xAABBCDD,0xAABDDFF,0x22334455,0x00000000,0x99663322
```

S6.5. 服务器程序从远程用户获取输入,并将输入保存在栈上分配的缓冲区 (图 1 中的 Region)中。然后,该缓冲区的地址存储在局部变量 `fmt` 中,服务器程序中的以下语句使用该变量: `printf(fmt)`。

执行此语句时,当前堆栈布局如图 1 所示。如果您是一名恶意攻击者,您能否构造输入,使得当输入被送入服务器程序时,服务器程序能够执行您的代码?请写下输入的实际内容 (您无需提供代码的确切内容;只需在答案中写上“恶意代码”,但需要将其放在正确的位置)。

S6.6. 如果你对问题 S6.5 的解答导致服务器输出超过十亿个字符,你的攻击可能需要一段时间才能成功。请修改你的解答,使输出的总字符数少于 80,000 个。

S6.7. 此题基于 S6.5 题。如果图 1 中区域 和区域 之间的距离不是 28 字节,而是 26 字节,该怎么办?这个数字不能被 4 整除,但每个 `%x` 格式字符串说明符都会将格式字符串指针移动 4 个字节。请构造你的格式字符串。

S6.8. ★ 本

题基于 S6.5 题。不同之处在于,我们并不清楚返回地址的具体存储位置。我们只知道它存储在以下地址之一:
`0xAABBCDA0`, `0xAABBCDA4`, `0xAABBCDA8` 或 `0xAABBCDAC`。

1. 请构造一个利用此漏洞的格式字符串,使得无论哪个地址才是正确的,攻击都能成功。打印出的字符总数必须少于 80,000 个。

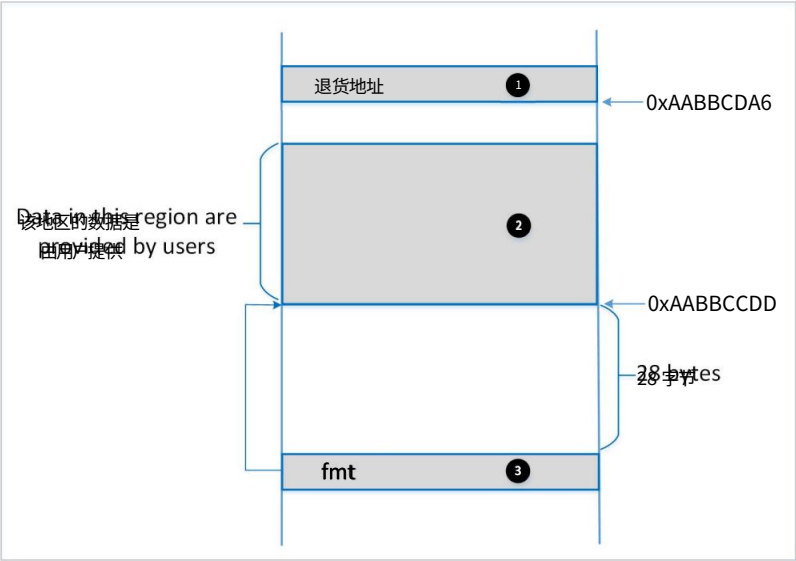


图 1:问题 S6.5 的堆栈布局。

2. 你能想出的最短格式字符串是什么（总数为打印出的字符数必须少于 80,000 个）。

S6.9. 如果编译器检测到 printf() 函数中的参数数量过多,可以发出警告。
与格式说明符的数量不匹配。请就此限制发表评论
这项应对措施。

S6.10. 由于 printf() 函数不需要任何特权,我们可以在执行此语句之前暂时禁用程序的特权;这样,即使格式化字符串
即使漏洞被利用,攻击者也无法获得太多权限。请就此想法发表评论。

S6.11. 如果我们使堆栈不可执行,是否仍然可以利用格式字符串漏洞
如何让受害程序生成一个 shell?

S6.12. 我们将利用返回 libc 技术来利用格式字符串漏洞。
请详细描述需要修改堆栈的哪一部分以及如何修改。
利用格式字符串漏洞即可实现此目的。请在描述解决方案时参考图 1。

S6.13. 如果我们想利用格式字符串漏洞向目标地址写入一个很小的数字（例如 0）,但由于格式字符串中必须包含 %x,该怎么办?
在 va 列表之前,printf() 函数打印出的字符数已经非零。
指针到达目标地址。是否仍然可以向目标地址写入0?